CRISC Domain B – 100 Exam-Style Questions (Part 3)

IT Risk Assessment – Fresh Scenarios (Answer on the Next Slide)

CRISC Mastery Series

October 21, 2026

Instructions

How to Use This Deck

Think like a risk practitioner: business objectives first, owners decide, assess before acting. Read for BEST, FIRST and MOST. Answer on the slide after each question.

Outline

1. Risk Identification
2. Risk Analysis
3. Risk Evaluation and Appetite
4. Risk Response
5. Controls
6. Monitoring and Reporting
7. BIA, Recovery and Third Parties
8. Governance and Risk Culture

Q1: Regulatory Horizon

Question

A regulator publishes a consultation paper on AI risk that may become law in 18 months. What should the risk practitioner do FIRST?

- (A) Wait until the law is passed
- (B) Ignore it as non-binding
- (C) Analyze potential exposure and monitor developments
- (D) Rewrite all AI policies today

Q1: Explanation

Correct Answer: C

- Consultation signals future obligations
- Early analysis enables planning
- Rewriting policies before certainty wastes effort
- Ignoring the horizon creates late surprises

Critical Trap

Consultations are early warnings, not certainties.

Q2: Board Risk Appetite

Question

The board states it has a LOW appetite for data breaches but a MODERATE appetite for service interruption. What does this mean for the risk assessment scope?

- (A) Treat all risks equally
- (B) Prioritize breach-related scenarios and use lighter scrutiny on brief outages
- (C) Ignore service interruption entirely
- (D) Focus only on fire risks

Q2: Explanation

Correct Answer: B

- Appetite differentials shape priorities
- Breach scenarios warrant deeper analysis
- Service risks still assessed but proportionate to appetite
- Scope should reflect the appetite profile

Critical Trap

Scope follows appetite differentials, not uniformity.

Q3: Business Model Change

Question

A firm shifts from one-time product sales to a subscription model. Which new risk area should be identified FIRST?

- (A) Office supply risk
- (B) Customer data lifecycle and recurring billing availability
- (C) Printer maintenance risk
- (D) Parking risk

Q3: Explanation

Correct Answer: B

- Subscription models depend on recurring billing and customer data
- Data lifecycle drives privacy and retention obligations
- Billing availability directly impacts revenue
- Physical risks remain but are secondary to the model

Critical Trap

New business models create new risk categories.

Q4: Employee Turnover

Question

High turnover in a security operations team creates which category of risk?

- (A) Equipment depreciation risk
- (B) Loss of institutional knowledge and control effectiveness degradation
- (C) Increase in advertising cost
- (D) Reduced tax liability

Q4: Explanation

Correct Answer: B

- Knowledge walks out with people
- Controls depend on skilled operators
- Replacement time extends exposure

Critical Trap

People risk is a control risk.

Q5: Post-Merger Integration

Question

After a merger, the acquired company uses unsupported software. What should the practitioner do FIRST?

- **A** Ignore legacy systems
- **B** Assess criticality of those systems and identify compensating controls
- **C** Migrate immediately without planning
- **D** File a legal complaint

Q5: Explanation

Correct Answer: B

- Unsupported software creates vulnerabilities
- Criticality defines urgency
- Compensating controls bridge the gap
- Immediate migration without planning increases risk

Critical Trap

Assess and compensate before mass migration.

Q6: Environmental Scanning

Question

The risk practitioner subscribes to threat intelligence but never uses it. What is the BEST improvement?

- (A) Cancel the subscription
- (B) Integrate intelligence into a routine risk identification process
- (C) Increase the subscription volume
- (D) Delegate reading to staff without a process

Q6: Explanation

Correct Answer: B

- Intelligence must feed a process
- Routine integration prevents forgotten alerts
- Volume without process adds noise

Critical Trap

Intelligence unused is intelligence wasted.

Q7: External Dependency

Question

The organization relies on a single public DNS provider. What category of risk should be identified?

- (A) Property tax risk
- (B) External dependency and concentration risk
- (C) Employee parking risk
- (D) Supplier branding risk

Q7: Explanation

Correct Answer: B

- Single external dependency means availability risk
- Concentration amplifies impact
- DNS is critical to customer-facing services

Critical Trap

External dependencies create availability risk.

Q8: Fraud Scheme

Question

Finance staff can create and approve vendor payments. What risk category is MOST relevant?

- A. Fraud and segregation-of-duties risk
- B. Advertising cost risk
- C. Software licensing risk
- D. Training cost risk

Q8: Explanation

Correct Answer: A

- Combined create/approve authority creates fraud exposure
- SoD prevents this
- Financial controls address the gap

Critical Trap

Combined duties enable fraud.

Q9: New Location

Question

Opening an office in a new country raises which FIRST-order risk identification concern?

- **A** Local labor laws, data residency, and regulatory differences
- **B** Office coffee brand
- **C** Local advertisement style
- **D** Parking spot count

Q9: Explanation

Correct Answer: A

- Legal and regulatory differences are primary
- Data residency affects architecture
- Labor law affects HR and data

Critical Trap

Geography brings legal and data risks.

Q10: Major Outage

Question

A cloud provider experiences a regional outage affecting several customers. What should the practitioner do NEXT?

- **A** Switch to another provider immediately
- **B** Assess whether the organization has similar exposure and revisit single-provider assumptions
- **C** Ignore it
- **D** Cancel the contract

Q10: Explanation

Correct Answer: B

- External events reveal your own exposure
- Revisit concentration assumptions
- Immediate switching may be infeasible or unnecessary

Critical Trap

External events reveal internal exposure.

Q11: Vendor Change

Question

A critical vendor changes its data-processing location without notice. What risk is most relevant?

- A. Data residency and legal jurisdiction
- B. Office rent
- C. Travel expense
- D. Holiday schedule

Q11: Explanation

Correct Answer: A

- Data location affects compliance and legal exposure
- Jurisdictional issues can trigger regulatory risk
- Location changes require re-assessment

Critical Trap

Data location is a regulatory and legal concern.

Q12: AI Model

Question

A new AI model is used to make credit decisions. What risk should be identified FIRST?

- (A) Model bias, explainability, and regulatory compliance
- (B) Office supply risk
- (C) Printer risk
- (D) Coffee risk

Q12: Explanation

Correct Answer: A

- Bias creates discrimination risk
- Explainability affects regulatory compliance
- Model failures cascade into credit decisions

Critical Trap

AI risks include bias, explainability, and compliance.

Q13: Weak Password Culture

Question

Employees reuse the same password across work and personal accounts. What risk category should be identified?

- (A) Credential compromise and lateral movement risk
- (B) Air conditioning risk
- (C) Fire suppression risk
- (D) Building security risk

Q13: Explanation

Correct Answer: A

- Reuse spreads compromise risk
- Lateral movement follows credential theft
- Compensating controls include MFA and credential monitoring

Critical Trap

Credential reuse enables widespread compromise.

Q14: Automation

Question

A process is automated without human review. What risk should be identified?

- A. Silent errors scaling automatically
- B. Travel risk
- C. Catering risk
- D. Office layout risk

Q14: Explanation

Correct Answer: A

- Automated errors scale
- Human review catches mistakes
- Monitoring and exception reporting are key controls

Critical Trap

Automation scales both efficiency and errors.

Q15: Data Quality

Question

Reports depend on inconsistent data sources. What risk should be identified?

A. Decision risk from inaccurate data
B. Fire risk
C. Library risk
D. Paving risk

Q15: Explanation

Correct Answer: A

- Inaccurate data drives wrong decisions
- Data quality is a business risk
- Lineage and validation reduce it

Critical Trap

Bad data creates bad decisions.

Q16: Correlation Assumption

Question

Analysts assume two risks are independent. Evidence suggests they co-occur. What is the impact on the analysis?

- A. No impact
- B. Combined risk may be significantly understated
- C. Risk decreases
- D. ALE becomes zero

Q16: Explanation

Correct Answer: B

- Independence underestimates joint probability
- Co-occurrence amplifies exposure
- Recalculate using correlation

Critical Trap

Independence assumptions understate correlated risk.

Q17: Qualitative Scale

Question

The organization uses High/Medium/Low but has no definitions. What is the BEST improvement?

- A. Remove the scale
- B. Define each level with measurable criteria
- C. Add more levels without definitions
- D. Use only colors

Q17: Explanation

Correct Answer: B

- Definitions reduce subjectivity
- Measurable criteria improve consistency
- More levels without meaning add noise

Critical Trap

Define what each level means.

Q18: Expert Calibration

Question

Experts consistently underestimate likelihood. What is the BEST corrective measure?

- A. Ask experts to estimate faster
- B. Calibrate estimates with historical data and independent challenge
- C. Average expert estimates
- D. Eliminate expert judgment

Q18: Explanation

Correct Answer: B

- Data calibrates optimism bias
- Independent challenge reduces anchoring
- Fast estimates increase error

Critical Trap

Data and challenge calibrate expert estimates.

Q19: Data Sampling

Question

A large transaction dataset is analyzed. Which approach is MOST defensible for extrapolation?

- A Selecting transactions alphabetically
- B A statistically valid sample with documented methodology
- C Choosing transactions that look interesting
- D Sampling only recent transactions

Q19: Explanation

Correct Answer: B

- Statistical sampling supports defensible extrapolation
- Documented methodology improves auditability
- Biased selection invalidates conclusions

Critical Trap

Sampling must be statistically defensible.

Q20: New System

Question

A new system has no historical data. What is the BEST analysis technique?

- A. Wait two years for data
- B. Scenario-based analysis with expert judgment and benchmarks
- C. Use last year's numbers from another system
- D. Skip analysis

Q20: Explanation

Correct Answer: B

- Scenarios and benchmarks suit new systems
- Expert judgment supplements missing data
- Borrowing unrelated data misleads

Critical Trap

New systems need scenarios, not fake data.

Q21: Model Overfit

Question

A model fits past incidents perfectly but fails on new cases. What is the issue?

- A Overfitting
- B Underfitting
- C Determinism
- D Randomness

Q21: Explanation

Correct Answer: A

- Overfitting memorizes past, not future
- Simpler, validated models generalize better
- Cross-validation reveals overfit

Critical Trap

Perfect fit on old data often fails on new data.

Q22: ALE with Downtime

Question

An hour of downtime costs $50K. A risk has 20% annual likelihood of a 4-hour outage. What is the ALE?

- A $40K
- B $10K
- C $100K
- D $200K

Q22: Explanation

Correct Answer: A

- Impact $= 4 \times 50K = \$200K$
- Likelihood $= 20\%$
- ALE $= 200K \times 0.2 = \$40K$
- \$200K is single-loss impact

Critical Trap

ALE equals impact multiplied by likelihood.

Q23: Sensitive Assumption

Question

The rating changes dramatically when the assumed detection time doubles. What should the practitioner do?

- (A) Ignore the sensitivity
- (B) Investigate detection capability and refine the analysis
- (C) Increase the rating to High
- (D) Report the highest possible figure

Q23: Explanation

Correct Answer: B

- Sensitive assumptions deserve validation
- Detection data improves accuracy
- Arbitrary changes mislead

Critical Trap

Test and refine the sensitive assumption.

Q24: Baseline Drift

Question

The risk profile gradually changes without any trigger event. What monitoring helps detect drift?

- A Annual snapshot only
- B Trend analysis over time
- C None
- D Marketing surveys

Q24: Explanation

Correct Answer: B

- Trends reveal gradual change
- Snapshots miss movement between them
- Continuous or periodic trend analysis catches drift

Critical Trap

Drift is invisible to single snapshots.

Q25: Worst-Case Use

Question

When is worst-case analysis MOST useful?

- (A) Routine operations
- (B) Business continuity and insurance decisions
- (C) Marketing budget decisions
- (D) Staff scheduling

Q25: Explanation

Correct Answer: B

- Worst-case informs continuity and insurance
- Routine decisions use expected values
- Marketing and staff use different measures

Critical Trap

Worst case informs resilience planning.

Q26: Data Fusion

Question

Internal incident data and threat intelligence conflict. What is the BEST approach?

- A. Use only internal data
- B. Reconcile by considering both sources and validate assumptions
- C. Use only intelligence
- D. Average the two

Q26: Explanation

Correct Answer: B

- Reconciliation improves accuracy
- Both sources have value
- Averages hide meaning

Critical Trap

Reconcile, do not average.

Q27: Data Silos

Question

Each department keeps its own risk spreadsheet. What is the MAIN analytical risk?

- A. Increased visibility
- B. Duplicated and inconsistent risk data
- C. Better ownership
- D. Faster reporting

Q27: Explanation

Correct Answer: B

- Silos duplicate and conflict
- Consistency requires a central register
- Visibility increases with centralization

Critical Trap

Siloed spreadsheets create inconsistency.

Q28: Analysis Purpose

Question

Risk analysis is BEST used to:

- (A) Eliminate the need for judgment
- (B) Provide structured information for decisions
- (C) Replace governance
- (D) Avoid escalation

Q28: Explanation

Correct Answer: B

- Analysis informs decisions
- Judgment and governance remain essential
- Escalation remains part of the process

Critical Trap

Analysis informs; decisions remain with people.

Q29: Change Threshold

Question

The business changes its impact definitions after the assessment. What should happen?

- A Nothing
- B Re-score affected risks using the new definitions
- C Ignore the new definitions
- D Delete the assessment

Q29: Explanation

Correct Answer: B

- Definitions drive scoring
- Consistent definitions keep ratings meaningful
- Ignoring definitions invalidates results

Critical Trap

When definitions change, ratings must follow.

Q30: Residual Estimation

Question

Residual risk estimation requires:

- (A) Inherent risk plus budget
- (B) Control effectiveness evidence
- (C) Marketing insight
- (D) Vendor invoices

Q30: Explanation

Correct Answer: B

- Residual depends on proven control effectiveness
- Evidence avoids guesswork
- Budget and invoices do not estimate risk

Critical Trap

Residual requires control evidence.

Q31: Tiered Appetite

Question

The organization sets a different appetite for customer data than internal data. What should the practitioner do?

- (A) Apply the strictest appetite everywhere
- (B) Reflect the tiered appetite in risk ratings and thresholds
- (C) Ignore the difference
- (D) Use only the weakest appetite

Q31: Explanation

Correct Answer: B

- Tiering matches sensitivity
- Thresholds should reflect the tier
- Applying strictest everywhere wastes effort

Critical Trap

Appetite tiers drive thresholds.

Q32: Appetite Escalation

Question

Business expansion inherently increases risk above appetite. What is the BEST action?

- A. Hide the increase
- B. Escalate for formal review and appetite reassessment
- C. Approve without escalation
- D. Cancel the expansion

Q32: Explanation

Correct Answer: B

- Higher risk above appetite requires review
- Leadership may adjust appetite
- Silent proceeding erodes governance

Critical Trap

Escalate when appetite conflicts with strategy.

Q33: Risk Tolerance in Incident

Question

An incident exceeded tolerance. What should happen FIRST?

- A. Close the incident without further action
- B. Investigate root cause and reassess exposure
- C. Change tolerance thresholds
- D. Increase the budget

Q33: Explanation

Correct Answer: B

- Root cause informs needed action
- Tolerance breaches signal governance failures
- Raising thresholds hides the signal

Critical Trap

Breach triggers investigation, not threshold shift.

Q34: Residual Escalation

Question

Residual risk after treatment is above appetite. Who decides next?

- (A) The controls team
- (B) The vendor
- (C) The authorized authority per governance
- (D) The auditor

Q34: Explanation

Correct Answer: C

- Above-appetite decisions require authority
- Options are more treatment or acceptance
- Vendor and audit do not own business risk

Critical Trap

Above appetite goes to the appropriate authority.

Q35: Acceptance Duration

Question

A formal risk acceptance should usually include which element?

- A. A hidden expiration
- B. An open-ended acceptance with no review
- C. A review date or expiration to trigger reassessment
- D. Only the analyst's signature

Q35: Explanation

Correct Answer: C

- Review dates prevent stale acceptance
- Open-ended acceptance hides drift
- Owners must re-commit

Critical Trap

Acceptance must expire and be revisited.

Q36: Appetite Communication

Question

Employees do not know the risk appetite. What is the BEST improvement?

- A. Post the appetite once per year
- B. Embed appetite thresholds into operating procedures and decisions
- C. Add more forms
- D. Ignore it

Q36: Explanation

Correct Answer: B

- Embedded thresholds guide daily choices
- Documentation alone is forgotten
- Procedures make appetite practical

Critical Trap

Embed appetite in operations.

Q37: Capacity and Strategy

Question

Strategic growth may breach capacity. What is the BEST action?

- A Ignore capacity
- B Model capacity impact and plan treatment before growth
- C Freeze all growth
- D Accept risk without analysis

Q37: Explanation

Correct Answer: B

- Capacity breaches threaten existence
- Proactive treatment supports growth
- Freezing everything avoids opportunity

Critical Trap

Plan before capacity is breached.

Q38: Loss of Appetite Confidence

Question

A rating was revised after political pressure from a business unit. What is the BEST response?

- **A** Accept the revision
- **B** Challenge pressure, document the independent basis and escalate if needed
- **C** Increase all ratings
- **D** Ignore the issue

Q38: Explanation

Correct Answer: B

- Independence protects integrity
- Documentation defends decisions
- Escalation addresses pressure

Critical Trap

Pressure must not drive ratings.

Q39: Appetite Drift

Question

Appetite was set five years ago and never revisited. What is the most likely issue?

- A. No issue
- B. Appetite may no longer reflect the business context
- C. Appetite is too high
- D. Appetite is too low

Q39: Explanation

Correct Answer: B

- Business context changes
- Appetite must be refreshed periodically
- Stale appetite misguides decisions

Critical Trap

Appetite must be revisited with strategy.

Q40: Post-Acceptance Monitoring

Question

An accepted risk reappears in an audit finding. What should the practitioner do?

- A. Ignore the finding
- B. Verify whether the acceptance is documented and whether conditions changed
- C. Withdraw the finding
- D. Blame the auditor

Q40: Explanation

Correct Answer: B

- Documented acceptance defends decisions
- Changed conditions may invalidate the original acceptance
- Audit findings should be reviewed, not withdrawn

Critical Trap

Verify the acceptance and current conditions.

Q41: Transfer Consequences

Question

Insurance covers financial loss but not downtime. What does this mean for the residual risk?

- A All risk is eliminated
- B Financial residual is covered but operational residual remains
- C Residual is fully transferred
- D Residual is zero

Q41: Explanation

Correct Answer: B

- Transfer is financial only
- Operational and reputational risk remain
- Plan controls for operational impact

Critical Trap

Transfer is financial, not operational.

Q42: Cheaper Alternative

Question

The first control exceeds the expected loss. What should the practitioner explore FIRST?

- A. Implement it anyway
- B. Search for less expensive controls with similar effect
- C. Accept the risk without review
- D. Cancel the project

Q42: Explanation

Correct Answer: B

- Alternatives may be more efficient
- Cost-benefit favors proportionate controls
- Unilateral acceptance without review is premature

Critical Trap

Explore cheaper options before accepting.

Q43: Data Custody

Question

Data stored with a vendor is encrypted by the organization. Who is accountable for the data?

- A. The vendor
- B. The organization
- C. The regulator
- D. The insurance provider

Q43: Explanation

Correct Answer: B

- Accountability remains with the data owner
- Encryption supports but does not shift accountability
- Regulators and insurers do not take accountability

Critical Trap

Accountability follows the data owner.

Q44: Response Tradeoff

Question

A response reduces likelihood but increases impact if it fails. What should the practitioner evaluate?

- **A** Ignore the new impact
- **B** The net effect on residual risk and new risks introduced
- **C** Only the likelihood reduction
- **D** Only implementation cost

Q44: Explanation

Correct Answer: B

- Net residual and new risk matter
- Secondary risks must be assessed
- Partial views mislead decisions

Critical Trap

Assess the net effect and secondary risks.

Q45: Avoidance Cost

Question

Terminating a service avoids its risk. What else must be considered?

- (A) Only the risk removed
- (B) Opportunity cost, contractual obligations and stakeholder impact
- (C) Only the cost of termination
- (D) Only legal fees

Q45: Explanation

Correct Answer: B

- Avoidance has opportunity and stakeholder costs
- Contracts may prevent immediate exit
- Full impact analysis is required

Critical Trap

Avoidance is not free; consider lost value.

Q46: Preventive Gap

Question

An attack succeeded despite preventive controls. What does this suggest?

- (A) Prevention is unnecessary
- (B) Prevention should be layered with detective and corrective controls
- (C) The risk is now zero
- (D) The controls were useless

Q46: Explanation

Correct Answer: B

- Layered controls support each other
- Prevention will not stop everything
- Detection and correction reduce impact

Critical Trap

Prevention needs detection and correction layers.

Q47: Detection Latency

Question

Detection latency is too long. What is the BEST improvement?

- (A) Add more prevention only
- (B) Tune detection, improve ingestion and alerting
- (C) Increase the budget without analysis
- (D) Cancel detection

Q47: Explanation

Correct Answer: B

- Detection tuning reduces latency
- Better ingestion improves coverage
- Prevention and detection complement

Critical Trap

Improve detection, not just prevention.

Q48: Compensating Adequacy

Question

A compensating control reduces risk but not below the original target. What should happen?

- A. Accept it
- B. Escalate because it does not achieve the risk objective
- C. Ignore the gap
- D. Remove the primary control

Q48: Explanation

Correct Answer: B

- Compensation must meet the risk target
- Escalation is required if not achieved
- Acceptance needs authorized decision

Critical Trap

Compensation must actually close the gap.

Q49: Response Ownership

Question

Who is accountable for ensuring a risk response is implemented?

- A. The project sponsor
- B. The risk owner
- C. The auditor
- D. The helpdesk

Q49: Explanation

Correct Answer: B

- Risk owners are accountable for responses
- Sponsors and auditors support but do not own the risk
- Helpdesk does not own business risk

Critical Trap

Risk owner oversees response execution.

Q50: Verification After Change

Question

A major infrastructure change occurred. What should the practitioner do NEXT?

- (A) Assume risk unchanged
- (B) Reassess risk and verify control effectiveness after change
- (C) Skip verification
- (D) Rely on old reports

Q50: Explanation

Correct Answer: B

- Changes alter risk
- Post-change verification confirms controls operate
- Old reports describe a different environment

Critical Trap

Re-verify after major changes.

Q51: Formal vs Informal Acceptance

Question

A risk is informally tolerated by staff. What is the BEST action?

- (A) Accept it as-is
- (B) Formalize the acceptance with the risk owner or treat the risk
- (C) Ignore it
- (D) Increase the budget

Q51: Explanation

Correct Answer: B

- Informal acceptance has no accountability
- Formal acceptance creates governance
- Treatment reduces exposure

Critical Trap

Informal tolerance is not acceptance.

Q52: Assurance Alternatives

Question

A vendor provides no third-party assurance. What should the practitioner do?

- **A** Rely on marketing claims
- **B** Perform direct assessment or require compensating controls
- **C** Skip the vendor
- **D** Sign without review

Q52: Explanation

Correct Answer: B

- Direct assessment provides assurance
- Compensating controls reduce exposure
- Marketing claims are not assurance

Critical Trap

Assurance requires evidence.

Q53: Exception Exit

Question

A policy exception is no longer required. What should be done?

- A. Keep it open
- B. Close it and update records
- C. Renew it automatically
- D. Ignore it

Q53: Explanation

Correct Answer: B

- Closing reduces unnecessary exposure
- Records should reflect the current state
- Automatic renewal keeps exceptions alive

Critical Trap

Close exceptions that are no longer needed.

Q54: Response Chain

Question

A control depends on a vendor that itself depends on a subcontractor. What is the KEY risk?

- A. Fourth-party dependency and loss of visibility
- B. Marketing cost
- C. Office lease
- D. Catering

Q54: Explanation

Correct Answer: A

- Fourth-party risk affects control reliability
- Visibility is reduced through layers
- Chain failures disrupt operations

Critical Trap

Chain dependencies require extended oversight.

Q55: Response Justification

Question

Which best justifies a mitigation investment?

A. Risk is low
B. Risk is above appetite and controls are cost-effective
C. Risk has not occurred
D. Risk is very unlikely

Q55: Explanation

Correct Answer: B

- Above-appetite risk requires action
- Cost-effectiveness protects value
- Past absence is not current risk

Critical Trap

Mitigate when above appetite and cost-effective.

Q56: Design Document

Question

A control is described only in a slide with no procedure. What is the deficiency type?

A. Design deficiency
B. Operating deficiency
C. Independence issue
D. Scope issue

Q56: Explanation

Correct Answer: A

- Without a procedure, the control lacks design
- Design must include roles and steps
- Operating issues assume a proper design

Critical Trap

Design requires procedures, not slides.

Q57: Defense Layers

Question

Which combination reduces the risk of common-mode failure?

- (A) Duplicate firewalls from the same vendor
- (B) Diverse network isolation, host controls, and monitoring
- (C) Only perimeter controls
- (D) Only endpoint controls

Q57: Explanation

Correct Answer: B

- Diversity limits common-mode failure
- Perimeter and endpoint only leave gaps
- Duplicates can share the same flaw

Critical Trap

Diversity limits common-mode failure.

Q58: Owner Evidence

Question

Which evidence BEST supports a control operating effectively?

- A. A policy exists
- B. The control was executed with evidence and exceptions reviewed
- C. A budget was allocated
- D. A team was formed

Q58: Explanation

Correct Answer: B

- Execution evidence proves operation
- Policies and budgets are inputs
- Team formation does not prove operation

Critical Trap

Execution evidence proves effectiveness.

Q59: Correction Effectiveness

Question

A corrective control restores service but loses 12 hours of data with an RPO of 4 hours. What does this mean?

- A. The corrective control is adequate
- B. The corrective control does not meet the RPO
- C. The RPO should be raised
- D. No issue exists

Q59: Explanation

Correct Answer: B

- RPO violation indicates data loss risk
- Corrective controls must support RPO
- RPO changes require business approval

Critical Trap

Correction must respect recovery objectives.

Q60: Audit Independence

Question

An internal audit report on IT controls was written by the person who built the controls. What is the MAIN issue?

- A. Independence is compromised
- B. The report is too long
- C. The report costs too much
- D. The report lacks visuals

Q60: Explanation

Correct Answer: A

- Independence affects objectivity
- Self-review produces bias
- Independent review is needed

Critical Trap

Self-assessment is not independent audit.

Q61: Gap Prioritization

Question

Multiple gaps are found. What MOST drives prioritization?

- A. The number of findings
- B. Exposure, likelihood and business impact
- C. The cheapest fixes
- D. The oldest gaps

Q61: Explanation

Correct Answer: B

- Exposure drives priority
- Impact aligns with business objectives
- Age and cost are secondary

Critical Trap

Prioritize by exposure, not count.

Q62: Automation Monitoring

Question

An automated control processes payments. What monitoring is essential?

- A None, it is automated
- B Exception monitoring, logging and periodic validation
- C Only annual review
- D Only manual override

Q62: Explanation

Correct Answer: B

- Automation needs monitoring
- Exceptions reveal failure
- Periodic validation confirms operation

Critical Trap

Automate with visibility.

Q63: Proportional Controls

Question

Which principle guides control proportionality?

- A. All controls must be equal
- B. Controls should match the risk level and appetite
- C. Controls must be automatic
- D. Controls must be manual

Q63: Explanation

Correct Answer: B

- Proportionality aligns effort with risk
- Low-risk controls should not exceed value
- High-risk controls need stronger measures

Critical Trap

Controls should fit the risk size.

Q64: Redundant Justified

Question

When is redundancy MOST justified?

- A. When the risk is low
- B. When common-mode failure could cause severe impact
- C. When the budget allows
- D. When it looks impressive

Q64: Explanation

Correct Answer: B

- Severe impact justifies redundancy
- Low risk rarely justifies duplicated cost
- Budget is not the driver

Critical Trap

Redundancy protects against severe impact.

Q65: CSA Validation

Question

What adds credibility to a control self-assessment?

- A Independence and evidence sampling
- B More self-reports
- C Faster completion
- D No follow-up

Q65: Explanation

Correct Answer: A

- Independent validation reduces bias
- Evidence sampling supports conclusions
- Rushed CSAs lack rigor

Critical Trap

CSA credibility requires validation.

Q66: Lagging Indicator

Question

Which is a LAGGING indicator of phishing exposure?

- A. Number of employees who failed last quarter's phishing simulation
- B. Click rate trends
- C. Email gateway rules
- D. Training attendance

Q66: Explanation

Correct Answer: A

- Past simulation failures are lagging
- Trends and configurations are inputs
- Attendance is an input

Critical Trap

Lagging indicators record what already happened.

Q67: Alert Fatigue

Question

Analysts ignore most alerts. What is the BEST fix?

- A. Increase alert volume
- B. Reduce and prioritize alerts with clear response playbooks
- C. Cancel monitoring
- D. Delegate to the helpdesk

Q67: Explanation

Correct Answer: B

- Prioritization improves response quality
- Playbooks standardize action
- Cancelling removes visibility

Critical Trap

Fewer, better alerts beat more, ignored alerts.

Q68: Regulator Reporting

Question

Which report format BEST supports a regulatory request?

- A. A marketing brochure
- B. A short executive dash
- C. A structured evidence-based report tied to requirements
- D. An email summary

Q68: Explanation

Correct Answer: C

- Regulators need evidence and traceability
- Structured reporting supports auditability
- Marketing and email are inadequate

Critical Trap

Regulators need evidence and structure.

Q69: Register Changes

Question

Which change should trigger an immediate register update?

- A. A new critical vendor was onboarded
- B. A staff meeting was scheduled
- C. A brochure was printed
- D. A holiday was announced

Q69: Explanation

Correct Answer: A

- Vendor onboarding changes exposure
- Critical vendors introduce third-party risk
- Administrative events do not change risk

Critical Trap

Onboarding critical vendors changes exposure.

Q70: Real-Time Limits

Question

Which scenario does NOT justify real-time monitoring?

- A High-value transaction integrity
- B Detection of network intrusions
- C Annual marketing plan progress
- D Malware outbreak detection

Q70: Explanation

Correct Answer: C

- Marketing plan progress is periodic
- Transaction, intrusion, and malware risks need real-time
- Periodic reviews suffice for strategic plans

Critical Trap

Real-time is for urgent risks.

Q71: KRI Overload

Question

The dashboard has 200 KRIs. What is the BEST remedy?

A. Add more visuals
B. Reduce to a focused set tied to appetite with clear ownership
C. Remove all KRIs
D. Increase the budget

Q71: Explanation

Correct Answer: B

- Focused metrics drive decisions
- Appetite alignment gives meaning
- Removing KRIs loses signal

Critical Trap

Fewer, owned KRIs improve response.

Q72: Indicator Sensitivity

Question

KRIs rarely change even when risk changes. What is the issue?

- (A) Insensitive thresholds
- (B) Excellent monitoring
- (C) Correct configuration
- (D) Data volume

Q72: Explanation

Correct Answer: A

- Insensitivity hides risk change
- Thresholds must track meaningful movement
- Stable indicators may be miscalibrated

Critical Trap

Insensitive KRIs hide risk.

Q73: Green Is Not Good

Question

The board interprets green as no risk. What should the practitioner explain?

- **A** Green means risk is within appetite, not absent
- **B** Green means risk is zero
- **C** Green means no action needed
- **D** Green means budget is sufficient

Q73: Explanation

Correct Answer: A

- Green means within tolerance
- Risk still exists
- Monitoring continues

Critical Trap

Green means within appetite, not risk-free.

Q74: Messaging Style

Question

Which phrase BEST supports executive risk discussion?

- (A) We patched 400 servers
- (B) Our breach exposure this quarter decreased 15% and remains within appetite
- (C) The SIEM correlated 500 events
- (D) The firewall vendor called

Q74: Explanation

Correct Answer: B

- Business language drives decisions
- Metrics support trend discussion
- Technical and anecdotal statements distract

Critical Trap

Business language drives decisions.

Q75: Root Cause of Miss

Question

An incident went undetected for 48 hours. What should be reviewed FIRST?

- A. Marketing plans
- B. Detection coverage, logging and alerting
- C. Vendor invoices
- D. Budget spreadsheets

Q75: Explanation

Correct Answer: B

- Detection latency points to monitoring gaps
- Coverage and alerting are direct controls
- Other items are not related

Critical Trap

Undetected incidents suggest monitoring gaps.

Q76: Register Quality

Question

Register entries lack owners and dates. What is the MAIN impact?

A. Ownership and tracking weaken, reducing accountability
B. Reporting improves
C. Costs decrease
D. Controls operate better

Q76: Explanation

Correct Answer: A

- Owners and dates are core accountability fields
- Missing them creates governance gaps
- Tracking requires structure

Critical Trap

Core fields enable accountability.

Q77: Threshold Ownership

Question

Escalation thresholds exist but no one knows who to notify. What should be added?

- A. Named recipients and contact paths per scenario
- B. A weekly newsletter
- C. More thresholds
- D. Another tool

Q77: Explanation

Correct Answer: A

- Escalation requires recipients
- Clarity improves response time
- Tools alone do not provide ownership

Critical Trap

Escalation needs recipients, not more rules.

Q78: Data Provenance

Question

KRI data has unclear sources. What is the BEST fix?

- A. Document data sources and validate integrity
- B. Use the data anyway
- C. Average across sources
- D. Delete the KRIs

Q78: Explanation

Correct Answer: A

- Provenance supports trust
- Validation confirms accuracy
- Unclear sources mislead

Critical Trap

Provenance builds KRI trust.

Q79: Audit Findings

Question

Audit findings are repeated year over year. What does this suggest?

- A. Findings are strong
- B. Remediation is ineffective
- C. Findings are unimportant
- D. The auditor is wrong

Q79: Explanation

Correct Answer: B

- Repeat findings signal unmet remediation
- Ownership and accountability are weak
- Escalation may be required

Critical Trap

Repeated findings signal failed remediation.

Q80: Directional Risk

Question

A KRI improves but stress indicators elsewhere worsen. What is the BEST view?

- (A) Ignore stress indicators
- (B) Combine KRI direction with other signals for a full picture
- (C) Use only the best KRI
- (D) Cancel the dashboard

Q80: Explanation

Correct Answer: B

- Single indicators mislead
- Combined signals reveal net direction
- Selective metrics distort decisions

Critical Trap

Combine signals for a true direction.

Q81: BIA Scope

Question

A BIA covers the revenue-critical order system but omits the payroll system. What is the MAIN risk?

- (A) Payroll risks are unassessed and may cause hidden business impact
- (B) Revenue systems are irrelevant
- (C) No issue
- (D) HR is not relevant

Q81: Explanation

Correct Answer: A

- Impact extends to employee trust and compliance
- BIA must include all critical processes
- Omitting payroll hides impact

Critical Trap

BIA must reflect all critical processes.

Q82: RTO Cascade

Question

A critical app has a 2-hour RTO. It depends on a database with a 6-hour RTO. What is the issue?

- A. No issue
- B. The dependency prevents meeting the RTO
- C. The database RTO is too short
- D. The app RTO is too long

Q82: Explanation

Correct Answer: B

- Dependent recovery times must align
- The database recovery time blocks app recovery
- Misalignment is a common BIA failure

Critical Trap

Dependencies must support the primary RTO.

Q83: RPO Cascade

Question

Data flows through three systems with RPOs of 1, 4, and 8 hours. What is the effective RPO?

- A 1 hour
- B 13 hours
- C 8 hours (the weakest link)
- D 4 hours

Q83: Explanation

Correct Answer: C

- The weakest link governs data loss
- Each system can lose up to its RPO
- Effective RPO is the worst RPO in the chain

Critical Trap

The weakest link determines effective RPO.

Q84: MTD Type

Question

Which definition fits an MTD of 12 hours?

- (A) No more than 12 hours of data loss
- (B) Total outage beyond 12 hours causes unacceptable impact
- (C) Restore within 12 hours
- (D) 12 hours is the average recovery time

Q84: Explanation

Correct Answer: B

- MTD is the impact threshold
- RTO is the recovery target
- RPO is about data loss

Critical Trap

MTD is the impact threshold.

Q85: BIA Ownership

Question

The BIA was written by IT without business input. What is the MAIN concern?

A. Business impact may be misjudged
B. IT budgets may be cut
C. The document is too long
D. The process is too fast

Q85: Explanation

Correct Answer: A

- Business owners know impact
- IT understands capability, not business value
- Misjudged impact skews recovery

Critical Trap

BIA needs business owners.

Q86: Backup Integrity

Question

Backups exist but are never tested. What is the KEY risk?

- A. Backups may fail on restore
- B. The cost of backups
- C. Backup speed
- D. Backup media branding

Q86: Explanation

Correct Answer: A

- Untested backups may not restore
- Restore testing is essential
- Success relies on verification

Critical Trap

Untested backups are unreliable backups.

Q87: DR Test Failure

Question

A DR test fails on a dependency not covered by the plan. What is the BEST action?

- A. Ignore the failure
- B. Update the DR plan to include the dependency and retest
- C. Raise the RTO
- D. Cancel tests

Q87: Explanation

Correct Answer: B

- Dependency gaps are common failures
- Plan updates close gaps
- RTO changes require business agreement

Critical Trap

Fix the plan, retest the gap.

Q88: Vendor Assessment Depth

Question

A low-risk vendor is assessed with a questionnaire. A high-risk vendor is also only assessed with a questionnaire. What is the issue?

- A. No issue
- B. Assessment depth should match vendor risk
- C. All vendors should be skipped
- D. All vendors need audits

Q88: Explanation

Correct Answer: B

- Proportionality applies to vendor risk
- High-risk vendors need deeper review
- Uniform shallow assessment understates risk

Critical Trap

Assessment depth follows risk level.

Q89: Subservice Organisations

Question

A SaaS vendor uses a subcontractor for storage. Which clause is MOST important?

- **A** Subcontractor flow-down obligations and notification
- **B** Vendor holiday party
- **C** Vendor branding rules
- **D** Pricing index

Q89: Explanation

Correct Answer: A

- Flow-down carries obligations to subcontractors
- Notification provides visibility
- Other clauses do not address risk

Critical Trap

Flow-down obligations protect the chain.

Q90: Vendor Exit

Question

The organization plans to end a contract. What is the FIRST step?

- A. Delete all data
- B. Confirm data return and destruction obligations plus transition plan
- C. Notify the press
- D. Cancel contracts immediately

Q90: Explanation

Correct Answer: B

- Exit requires data obligations and transition
- Unsafe exit risks data loss or legal issues
- Immediate cancellation may breach terms

Critical Trap

Exit needs a plan, not a scramble.

Q91: Risk Register Value

Question

Which outcome MOST shows a register is being used effectively?

- A. It grows in size each month
- B. It drives decisions, escalations and resource allocation
- C. It stays unchanged
- D. It has many pages

Q91: Explanation

Correct Answer: B

- Use is proven by decisions
- Size and length do not prove value
- Static registers may be outdated

Critical Trap

Value is shown in decisions, not pages.

Q92: Owner Motivation

Question

An owner refuses to accept the risk. What is the BEST practitioner response?

- A. Force acceptance
- B. Understand concerns, review the evidence and escalate if unresolved
- C. Ignore the owner
- D. Increase the rating

Q92: Explanation

Correct Answer: B

- Owners may have context
- Review evidence addresses concerns
- Escalation resolves disagreements

Critical Trap

Understand and escalate, do not force.

Q93: Culture Signals

Question

Which behavior MOST damages risk culture?

- A. Leaders openly discussing risks
- B. Leaders punishing those who escalate
- C. Encouraging early reporting
- D. Rewarding proactive risk management

Q93: Explanation

Correct Answer: B

- Punishment discourages transparency
- Silence hides exposure
- Openness improves risk management

Critical Trap

Punishment kills honest reporting.

Q94: Line Independence

Question

In the three lines model, which role should audit NOT perform?

- **A** Independent assurance of controls
- **B** Designing and operating controls
- **C** Reporting to the board
- **D** Following up on findings

Q94: Explanation

Correct Answer: B

- Audit must remain independent
- Designing controls compromises independence
- Assurance is audit's role

Critical Trap

Audit must not build what it audits.

Q95: Practitioner Influence

Question

How does the practitioner BEST influence decisions?

- A. Make decisions for owners
- B. Provide clear analysis, options and consequences
- C. Withhold evidence
- D. Escalate every issue

Q95: Explanation

Correct Answer: B

- Options and consequences support owners
- Transparency builds trust
- Withholding evidence damages credibility

Critical Trap

Influence through clarity, not control.

Q96: New Tech Adoption

Question

The business wants to adopt a new AI tool urgently. What is the BEST governance response?

- **A** Block immediately
- **B** Conduct a proportionate risk assessment and approve or escalate
- **C** Approve without review
- **D** Delay indefinitely

Q96: Explanation

Correct Answer: B

- Proportional assessment supports speed and safety
- Escalation follows risk thresholds
- Blocking and indefinite delay harm opportunity

Critical Trap

Proportionate assessment fits urgent adoption.

Q97: Assessment Timing

Question

Which event should trigger a risk reassessment?

- A. A major change in leadership strategy
- B. A routine printer replacement
- C. A holiday announcement
- D. A marketing campaign

Q97: Explanation

Correct Answer: A

- Strategic change alters risk
- Routine items rarely alter exposure
- Reassess when strategy changes

Critical Trap

Strategic change triggers reassessment.

Q98: Executive Language

Question

A business leader says “we do not want to talk about IT issues.” What is the BEST practitioner response?

- **A** Use technical jargon
- **B** Reframe as business exposure, options and consequences
- **C** Ignore the leader
- **D** Escalate to the board

Q98: Explanation

Correct Answer: B

- Business language enables engagement
- Reframing builds dialogue
- Escalation is for unresolved issues

Critical Trap

Speak business language to business leaders.

Q99: Stale Data Risk

Question

A register entry was last reviewed three years ago. What is the BEST action?

- A. Assume still valid
- B. Review with the owner to confirm current status
- C. Delete the entry
- D. Increase the rating

Q99: Explanation

Correct Answer: B

- Owners can confirm current state
- Review prevents misinformed decisions
- Assumption increases risk

Critical Trap

Confirm stale entries with owners.

Q100: Owner Handover

Question

The owner of a critical risk is leaving the company. What should happen FIRST?

- A. Close the risk
- B. Hand over ownership formally to an appropriate successor
- C. Ignore the departure
- D. Lower the rating

Q100: Explanation

Correct Answer: B

- Formal handover preserves accountability
- Successor must have authority
- Ignoring departure creates gaps

Critical Trap

Ownership must be handed over formally.

Exam Mindset Summary

Remember

- **FIRST:** understand context and assess before acting
- **Owners decide:** business owners accept risk; the practitioner advises
- **Appetite:** compare residual risk to appetite, then escalate or treat
- **Accountability** cannot be outsourced or transferred
- **Monitor:** validate data, trend it, and keep the register current

Good Luck on Your CRISC Exam!